

NIST CSF COMPLIANCE ASSESSMENT

Organization: Acme Corporation
Framework: NIST Cybersecurity Framework (CSF) v1.1

Assessment Date: May 02, 2026
Assessed By: Brian Pascal
Classification: CONFIDENTIAL

OVERALL COMPLIANCE
SCORE

69.1%

NEEDS IMPROVEMENT

Total Controls	Implemented	Partial	Not Implemented
47	23	19	5

EXECUTIVE SUMMARY

This report presents the results of a NIST Cybersecurity Framework (CSF) v1.1 compliance assessment conducted for **Acme Corporation** on May 02, 2026. The assessment evaluated 47 controls across the five NIST CSF functions: Identify, Protect, Detect, Respond, and Recover.

The organization achieved an overall compliance score of **69.1%**, rated as **NEEDS IMPROVEMENT**. Of 47 total controls assessed, 23 are fully implemented, 19 are partially implemented, and 5 have not been implemented. Immediate remediation priority should be placed on the Not Implemented controls within the Respond and Recover functions, as these represent the greatest risk exposure during an active security incident.

CSF Function	Controls	Implemented	Partial	Not Impl.	Score	Status
Identify	12	7	4	1	75.0%	COMPLIANT
Protect	14	8	5	1	75.0%	COMPLIANT
Detect	8	5	3	0	81.2%	COMPLIANT
Respond	8	3	4	1	62.5%	NEEDS IMPROVEMENT
Recover	5	0	3	2	30.0%	NON-COMPLIANT

IDENTIFY (ID)

75.0
%

COMPLIANT

Implemented: 7 Partial: 4 Not Implemented: 1

Control ID	Category	Description	Status
ID.AM-1	Asset Management	Physical devices and systems within the organization are inventoried.	Implemented
ID.AM-2	Asset Management	Software platforms and applications within the organization are inventoried.	Implemented
ID.AM-3	Asset Management	Organizational communication and data flows are mapped.	Partial
ID.AM-5	Asset Management	Resources (e.g., hardware, devices, data, time, personnel) are prioritized based on their classification, criticality, and business value.	Partial
ID.BE-1	Business Environment	The organization's role in the supply chain is identified and communicated.	Implemented
ID.BE-3	Business Environment	Priorities for organizational mission, objectives, and activities are established and communicated.	Implemented
ID.GV-1	Governance	Organizational cybersecurity policy is established and communicated.	Implemented
ID.GV-3	Governance	Legal and regulatory requirements regarding cybersecurity are understood and managed.	Partial
ID.RA-1	Risk Assessment	Asset vulnerabilities are identified and documented.	Implemented
ID.RA-3	Risk Assessment	Threats, both internal and external, are identified and documented.	Partial
ID.RA-5	Risk Assessment	Threats, vulnerabilities, likelihoods, and impacts are used to determine risk.	Implemented
ID.RM-1	Risk Management	Risk management processes are established, managed, and agreed to by stakeholders.	Not Implemented

PROTECT (PR)

75.0
%

COMPLIANT

Implemented: 8 Partial: 5 Not Implemented: 1

Control ID	Category	Description	Status
PR.AC-1	Access Control	Identities and credentials are issued, managed, verified, revoked, and audited for authorized devices, users, and processes.	Implemented
PR.AC-3	Access Control	Remote access is managed.	Implemented
PR.AC-4	Access Control	Access permissions and authorizations are managed, incorporating the principles of least privilege and separation of duties.	Partial
PR.AC-5	Access Control	Network integrity is protected (e.g., network segregation, network segmentation).	Partial
PR.AT-1	Awareness & Training	All users are informed and trained.	Implemented
PR.AT-2	Awareness & Training	Privileged users understand their roles and responsibilities.	Implemented
PR.DS-1	Data Security	Data-at-rest is protected.	Implemented
PR.DS-2	Data Security	Data-in-transit is protected.	Implemented
PR.DS-5	Data Security	Protections against data leaks are implemented.	Partial
PR.IP-1	Info Protection	A baseline configuration of information technology/industrial control systems is created and maintained.	Not Implemented
PR.IP-3	Info Protection	Configuration change control processes are in place.	Partial
PR.MA-1	Maintenance	Maintenance and repair of organizational assets are performed and logged.	Implemented
PR.PT-1	Protective Technology	Audit/log records are determined, documented, implemented, and reviewed.	Implemented
PR.PT-3	Protective Technology	The principle of least functionality is incorporated by configuring systems to provide only essential capabilities.	Partial

DETECT (DE)

81.2%

COMPLIANT

Implemented: 5 Partial: 3 Not Implemented: 0

Control ID	Category	Description	Status
DE.AE-1	Anomaly & Events	A baseline of network operations and expected data flows is established and managed.	Partial
DE.AE-2	Anomaly & Events	Detected events are analyzed to understand attack targets and methods.	Implemented
DE.AE-3	Anomaly & Events	Event data are collected and correlated from multiple sources and sensors.	Implemented
DE.CM-1	Continuous Monitoring	The network is monitored to detect potential cybersecurity events.	Implemented
DE.CM-3	Continuous Monitoring	Personnel activity is monitored to detect potential cybersecurity events.	Partial
DE.CM-7	Continuous Monitoring	Monitoring for unauthorized personnel, connections, devices, and software is performed.	Partial
DE.DP-1	Detection Processes	Roles and responsibilities for detection are well defined to ensure accountability.	Implemented
DE.DP-4	Detection Processes	Event detection information is communicated.	Implemented

RESPOND (RS)

62.5%

NEEDS
IMPROVEMENT

Implemented: 3 Partial: 4 Not Implemented: 1

Control ID	Category	Description	Status
RS.RP-1	Response Planning	Response plan is executed during or after an incident.	Partial
RS.CO-1	Communications	Personnel know their roles and order of operations when a response is needed.	Implemented
RS.CO-3	Communications	Information is shared consistent with response plans.	Partial
RS.AN-1	Analysis	Notifications from detection systems are investigated.	Implemented
RS.AN-4	Analysis	Incidents are categorized consistent with response plans.	Implemented
RS.MI-1	Mitigation	Incidents are contained.	Partial
RS.MI-2	Mitigation	Incidents are mitigated.	Partial
RS.IM-1	Improvements	Response plans incorporate lessons learned.	Not Implemented

RECOVER (RC)

30.0
%

NON-COMPLIANT

Implemented: 0 Partial: 3 Not Implemented: 2

Control ID	Category	Description	Status
RC.RP-1	Recovery Planning	Recovery plan is executed during or after a cybersecurity incident.	Partial
RC.IM-1	Improvements	Recovery plans incorporate lessons learned.	Not Implemented
RC.IM-2	Improvements	Recovery strategies are updated.	Partial
RC.CO-1	Communications	Public relations are managed.	Not Implemented
RC.CO-3	Communications	Recovery activities are communicated to internal and external stakeholders.	Partial

RECOMMENDATIONS

Priority 1 — Immediate Action (Not Implemented Controls)

Control ID	Function	Description	Recommended Action
ID.RM-1	Identify	Risk management processes are established, managed, and agreed to by stakeholder...	Establish a formal risk management committee. Document risk appetite and tolerance thresholds. Obtain executive sign-off.
PR.IP-1	Protect	A baseline configuration of information technology/industrial control systems is...	Develop and publish a hardening baseline using CIS Benchmarks. Enforce via configuration management tooling.
RS.IM-1	Respond	Response plans incorporate lessons learned....	Schedule quarterly IR retrospectives. Create a lessons-learned register. Update playbooks after each incident.
RC.IM-1	Recover	Recovery plans incorporate lessons learned....	Integrate lessons learned into BCP/DRP. Conduct annual tabletop exercises.
RC.CO-1	Recover	Public relations are managed....	Develop a communications plan for external stakeholders. Designate a PR lead for security incidents.

Priority 2 — Short-Term (Partial Controls)

There are 19 partially implemented controls requiring completion. Focus first on PR.AC-4 (least privilege enforcement), PR.IP-3 (change control), RS.MI-1 and RS.MI-2 (incident containment and mitigation), and RC.RP-1 (recovery plan execution). These partial controls in the Respond and Recover functions represent the highest risk during an active incident.